

TENANT_ISOLATION.md

1. Objetivo

Garantizar aislamiento total entre tenants en AIPanel, abarcando: - Base de datos - API y autenticación - Procesos asíncronos - Documentos y almacenamiento - Memoria del agente - Caché y logs - Auditoría

2. Aislamiento a Nivel de Base de Datos

2.1. Estructura Multi-Tenant

Todas las tablas sensibles incluyen `tenant_id`.

2.2. Filtro Automático en ORM

Cada consulta del backend se ejecuta con filtro obligatorio:

```
WHERE tenant_id = current_tenant
```

Se aplica mediante dependencia global.

2.3. Row-Level Security (Opcional)

```
ALTER TABLE agents ENABLE ROW LEVEL SECURITY;  
CREATE POLICY tenant_isolation_policy ON agents  
USING (tenant_id = current_setting('app.current_tenant'));
```

2.4. Validación de Owner

El backend valida que cada recurso pertenezca al tenant actual.

3. Aislamiento a Nivel de API

3.1. Tokens JWT

Cada token incluye: - user_id - tenant_id - rol

3.2. Filtro Automático

Toda request verifica: - Token válido - Tenant correcto - Permisos del rol

3.3. Bloqueo de Enumeración

IDs no pueden verse entre tenants.

4. Aislamiento de Documentos

4.1. Rutas de Almacenamiento

Si se usa S3:

```
s3://aipanel/{tenant_id}/{document_id}/original.pdf
```

4.2. Asociación Obligatoria

- documentos → tenant_id
- chunks → document_id

4.3. Reglas de Acceso

Solo el tenant propietario puede: - leer - procesar - eliminar

5. Aislamiento en Procesos Asíncronos (Celery)

5.1. Todas las Tareas Incluyen Tenant

```
process_document.delay(document_id, tenant_id)
```

5.2. Validación Interna

Cada tarea valida que el documento pertenezca al tenant.

5.3. Filas de Trabajo (Opcional)

Una cola por tenant:

```
celery-aipanel-tenant-{id}
```

6. Aislamiento de Memoria y Contexto del Agente

6.1. Memoria Guardada por Tenant

- Resúmenes

- Embeddings
- Datos persistentes
- Conversaciones

6.2. Compartimentalización

No existe cruce de información.

7. Caché y Redis

Clave decorada para evitar colisiones:

```
cache:{tenant_id}:{resource}:{id}
```

Reduciendo riesgo de filtrado o colisión de datos.

8. Auditoría

Log registrado con: - tenant_id - user_id - acción - objeto - estado - timestamp

Permite trazabilidad total.

9. Seguridad Contra Abuso y Sobrecarga

- Rate-limit por tenant.
 - Umbrales de uso.
 - Suspensión automática en tokens o requests excesivas.
 - Límite de tamaño en documentos.
-

10. Resumen

Este documento define los mecanismos necesarios para garantizar: - aislamiento completo entre tenants, - cumplimiento de estándares empresariales, - seguridad operacional, - y protección de datos críticos.